

Documentation sur la

Détection des attaques Active Directory avec Wazuh

Kerberoasting – DCSync – Pass-the-Hash

Encadré par :

Tarek Khouloud

Zakaria Elkhatib

Mohamed Amine Khoubach

Élaboré par :

Safia Benali

Table des matières

1 Présentation de l'environnement **1**
1.1 Objectif 1
1.2 Environnement de test 1
1.3 Intégration d'Active Directory avec Wazuh 1

2 Présentation des attaques Active Directory **2**
2.1 Kerberoasting : 2
2.2 DCSync : 2
2.3 Pass-the-Hash : 2
2.4 Comparaison des trois techniques 2

3 Détection du Kerberoasting **3**
3.1 Préparation du compte de service 3
3.2 Configuration de l'audit Kerberos 3
3.3 Simulation de l'attaque 3
3.4 Règle de détection Wazuh 4
3.5 Vérification de l'alerte 4
3.6 Notification par e-mail 5

4 Détection du DCSync **7**
4.1 Configuration des droits de réplication 7
4.2 Configuration de l'audit Active Directory 7
4.3 Simulation de l'attaque 7
4.4 Règle de détection Wazuh 8
4.5 Vérification de l'alerte 8
4.6 Notification par e-mail 9

5 Détection du Pass-the-Hash **11**
5.1 Préparation du scénario 11
5.2 Simulation de l'authentification NTLM 11
5.3 Règle de détection Wazuh 12
5.4 Vérification de l'alerte 12
5.5 Notification par e-mail 13

1 Présentation de l'environnement

1.1 Objectif

Cette documentation présente la mise en place et la validation de trois scénarios de sécurité ciblant Active Directory : Kerberoasting, DCSync et Pass-the-Hash. Elle décrit leur principe, les conditions nécessaires à leur simulation et les éléments de détection collectés par Wazuh.

1.2 Environnement de test

Il repose sur un domaine Active Directory `gstr.local` et un réseau VirtualBox de test. Le contrôleur de domaine centralise les événements Windows transmis au serveur Wazuh.

Machine / rôle	**Adresse IP**
Contrôleur de domaine Windows Server	192.168.56.30
Wazuh Manager	192.168.56.20
Kali Linux (poste de simulation)	192.168.56.50
Windows 10 (membre du domaine)	192.168.56.40

TABLE 1.1 – Adressage de l'environnement Active Directory

1.3 Intégration d'Active Directory avec Wazuh

Un agent Wazuh installé sur le contrôleur de domaine collecte les événements du journal Windows `Security`. L'activation des stratégies d'audit adaptées est nécessaire pour produire les événements utiles aux scénarios étudiés.

```
<localfile>
  <location>Security</location>
  <log_format>eventchannel</log_format>
  <query>Event/System[EventID != 5145 and EventID != 5156 and EventID != 5447 and
    EventID != 4656 and EventID != 4658 and EventID != 4663 and EventID != 4660 and
    EventID != 4670 and EventID != 4690 and EventID != 4703 and EventID != 4907 and
    EventID != 5152 and EventID != 5157]</query>
</localfile>
```

FIGURE 1.1 – Configuration de la collecte des événements de sécurité Windows dans Wazuh.

2 Présentation des attaques Active Directory

2.1 Kerberoasting :

Le Kerberoasting consiste à demander un ticket de service Kerberos (TGS) associé à un compte disposant d'un SPN. Le ticket obtenu peut faire l'objet d'une tentative de cassage hors ligne afin de retrouver le mot de passe du compte de service. Un compte de domaine authentifié suffit généralement à demander ce ticket. Cette technique correspond à MITRE ATT&CK **T1558.003**.

2.2 DCSync :

Le DCSync détourne le mécanisme de réplication d'Active Directory afin de demander des secrets de comptes, notamment des hachages NTLM. Il nécessite des droits de réplication appropriés sur le domaine, mais pas d'exécution de code sur le contrôleur de domaine. Cette technique correspond à **T1003.006**.

2.3 Pass-the-Hash :

Le Pass-the-Hash permet de s'authentifier sur un système utilisant NTLM à partir d'un hachage déjà obtenu, sans connaître le mot de passe en clair. Il sert notamment au mouvement latéral et correspond à **T1550.002**.

2.4 Comparaison des trois techniques

Critère	**Kerberoasting**	**DCSync**	**Pass-the-Hash**
Objectif	Obtenir un ticket à casser	Extraire des secrets AD	Réutiliser un hash NTLM
Prérequis	Compte AD authentifié et SPN	Droits de réplication	Hash NTLM valide
Événement principal	4769	4662	4624
MITRE	T1558.003	T1003.006	T1550.002

Table 2.1 – Comparaison des attaques ciblant Active Directory

3 Détection du Kerberoasting

3.1 Préparation du compte de service

Dans le cadre de ce scénario, le compte de service est associé au SPN . Un mot de passe de test est utilisé afin d'illustrer les risques liés aux comptes de service insuffisamment protégés.

```
PS C:\Users\Administrateur> setspn -A MSSQLSvc/sql01.gstr.local:1433 svc_sql
Vérification du domaine DC=gstr,DC=local
CN=svc sql,OU=PFE,DC=gstr,DC=local
        MSSQLSvc/sql01.gstr.local:1433

Détection d'un SPN en double, opération abandonnée.
PS C:\Users\Administrateur>
```

FIGURE 3.1 – Compte de service et SPN configurés dans Active Directory

3.2 Configuration de l'audit Kerberos

Afin de journaliser les événements liés aux activités Kerberos, l'audit des opérations de tickets de service a été activé sur le contrôleur de domaine, permettant notamment la génération de l'événement 4769.

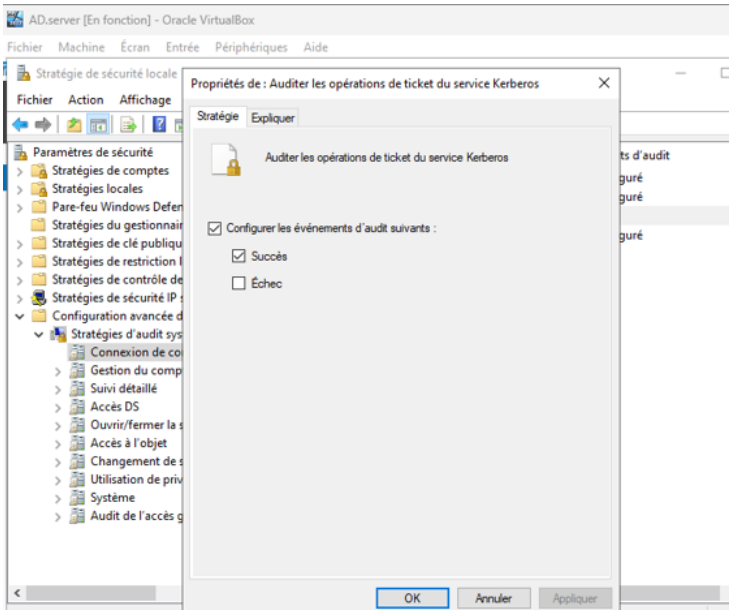


FIGURE 3.2 – Configuration de l'audit des tickets de service Kerberos

3.3 Simulation de l'attaque

Depuis Kali Linux, une demande de ticket de service est réalisée dans le laboratoire à l'aide d'Impacket. Le résultat est enregistré pour une analyse hors ligne. Le scénario documenté montre un ticket utilisant RC4, associé au compte de service ciblé.

```
┌──(safia㉿sofia)-[~]
└─$ PYTHONPATH=~/old_crypto_lib impacket-GetUserSPNs gstr.local/safya:GSTRGSTR20@@ -dc-ip 192.168.56.30 -request -out
putfile hashes_test.txt
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

ServicePrincipalName           Name     MemberOf                                          PasswordLastSet  LastLogon
          Delegation
-----------------------------  -------  ------------------------------------------------  ---------------  -----------
---------------  ----------
MSSQLSvc/sql01.gstr.local:1433  svc_sql  CN=Admins du domaine,CN=Users,DC=gstr,DC=local  <never>          2026-08-12
10:15:30.453803
```

FIGURE 3.3 – Résultat de la demande de ticket Kerberos depuis Kali Linux

Le ticket extrait est soumis à Hashcat afin de tenter de retrouver le mot de passe du compte de service à partir de sa représentation chiffrée.

```
$krb5tgs$23$*svc_sql$GSTR.LOCAL$gstr.local/svc_sql*$792bdaf09c40bb35e7a13e75d700b467$0ee06e9bdec97af101f3bf9b544601a1
7d71e9c53c2caf3466885b98c522142445ea3580c9a42d026b0195dd3504542ccb692e40819ae104a2d58dbd812e7e5602025cc28f27375258c77
6fc7021bd67b38bd1d34fba8317509373696e772af824308af848ded55cf07ba9964df4c4a62818515ad478103933a9ba7da2964136ea567de38d
27fa42f09da901e0c57ac79aff7acacb2a66cf7c641da39979c2df5dddd2e73ba2264f73b65160dea47c9cc67437473fa1af1073ac5a03c23b8da
9bf70f381a4bcf5de3c7184dd960f284f3c1d137859b5efd8b5eb31c928e0b446aff880e1207743e0d6cc10825044c132d7c1446ff8badc73a9fd
22c8b38df87f169539272fadebae00133579597e3fc916ebf1cd248c7fdb27e82d4f1fac56922151548d8fbe9ee7dd881dcc2e882d93e4af08cea
63bdf9fa2325b4a115a5958c6a09353784881e2295ff604656f91a09204e9c0afe357a9fb079d36bda0896d067572368897310ff5df8bcc952259
3a6b9114a62744ea2170d31bf1d1c7da7a4e8924b69cc67a76e7d193eb06e2f36ac53b279cd89e3c2e81589b71c7ecd4f476255cd7be38adbe5f1
24e01393310a85b3d197d6c627d35da1e2f772512690179967c27e3ee964fb7ad3c06a235dc06cc7bbda88b7625c3318394338f6f1a50c87ab014
45389314661dcf5cad87490803e74b6c6435f667ab1fcd5bc28a8068404c2cc53205c89a5a10fd902a9b77091547052eb1f9f04d3be5b650e867f
abefb00550c21e230fbc03e6b87ebfa748ffef45716b3e773985a5acbefecd7b3930c6e7750d49c784bc0c650fadd1356493e3d6bb45d1824bcc3
1a6cab5e25e301786c051d7742b2da2b98b3704be8de2eed78b303a5d532599ef9479e0f61dde73ccfd4dfc072fced91849afffdafeb53bf63d29
34c1f3b583c7e50b41b1eda3e20b9367f7a2874a9948173ac8f4e6fb21ab2ef8ae690356b550b3893ea6762b85ea96e5e46ae191eb27d1fa645d6
fa4fa54b49c759627c3d2b9de6dc33bf653347b52e89ccba88bc6ef3512b0d5a91a82806d9511a81d9ec804f75a97ef8f86bf85d1654295f71959
0811e53de8a2bd09f9dc7eb32a14f921f008f91505eff51e5eaec5c705af01cc64b93f22f35996016adf19c630ad7f0eef93c4e19482ac3a59583
ae76de8c0c675a567821a4b319937b826dc714980f7e9d2fec505386c1d49e03449f93b3dd04d4a31b0e65392f3bda1407d29a0ba7b4b1267db63
685e758f6f99dea0e75e51dd9207ef086958e2ff5b67730572176825535e1ce6b276630c1f0dc623a5c2540c4f260775405a79abdf0b19fb30e1a
713a296db8c8bdad6d7d6b998f9a5c46320cbe7ec09ac8f33d1b8a85a9d00d8cf9bf8bc69ef38ae120ab88d839f308ef27e6a86ac2c32b8bdcc58
4fb982445c0:Pechi120268

Session..........: hashcat
Status...........: Cracked
Hash.Mode........: 13100 (Kerberos 5, etype 23, TGS-REP)
Hash.Target......: $krb5tgs$23$*svc_sql$GSTR.LOCAL$gstr.local/svc_sql*...2445c0
```

FIGURE 3.4 – Cassage du hash avec Hashcat

3.4 Règle de détection Wazuh

La détection examine les événements **4769**, en particulier le compte de service demandé, l'adresse source et le type de chiffrement du ticket. L'utilisation de RC4 (`0x17`) constitue un indicateur à analyser dans son contexte et ne suffit pas, isolément, à prouver une attaque.

```
<rule id="100132" level="12">
  <if_sid>60103</if_sid>
  <field name="win.system.eventID">^4769$</field>
  <field name="win.eventdata.ticketEncryptionType">^0x17$</field>
  <description>Kerberoasting détecté : demande de ticket Kerberos avec chiffrement RC4 (faible) pour le service $(win.eventdata.serviceName), par le compte $(win.eventdata.targetUserName)</description>
  <mitre>
    <id>T1558.003</id>
  </mitre>
  <group>attack,gstr,</group>
</rule>
```

FIGURE 3.5 – Règle Wazuh utilisée pour la détection du Kerberoasting

3.5 Vérification de l'alerte

Suite à la demande du ticket Kerberos, l'événement Windows 4769 est collecté et analysé par Wazuh. La règle de détection se déclenche et génère l'alerte présentée ci-dessous.

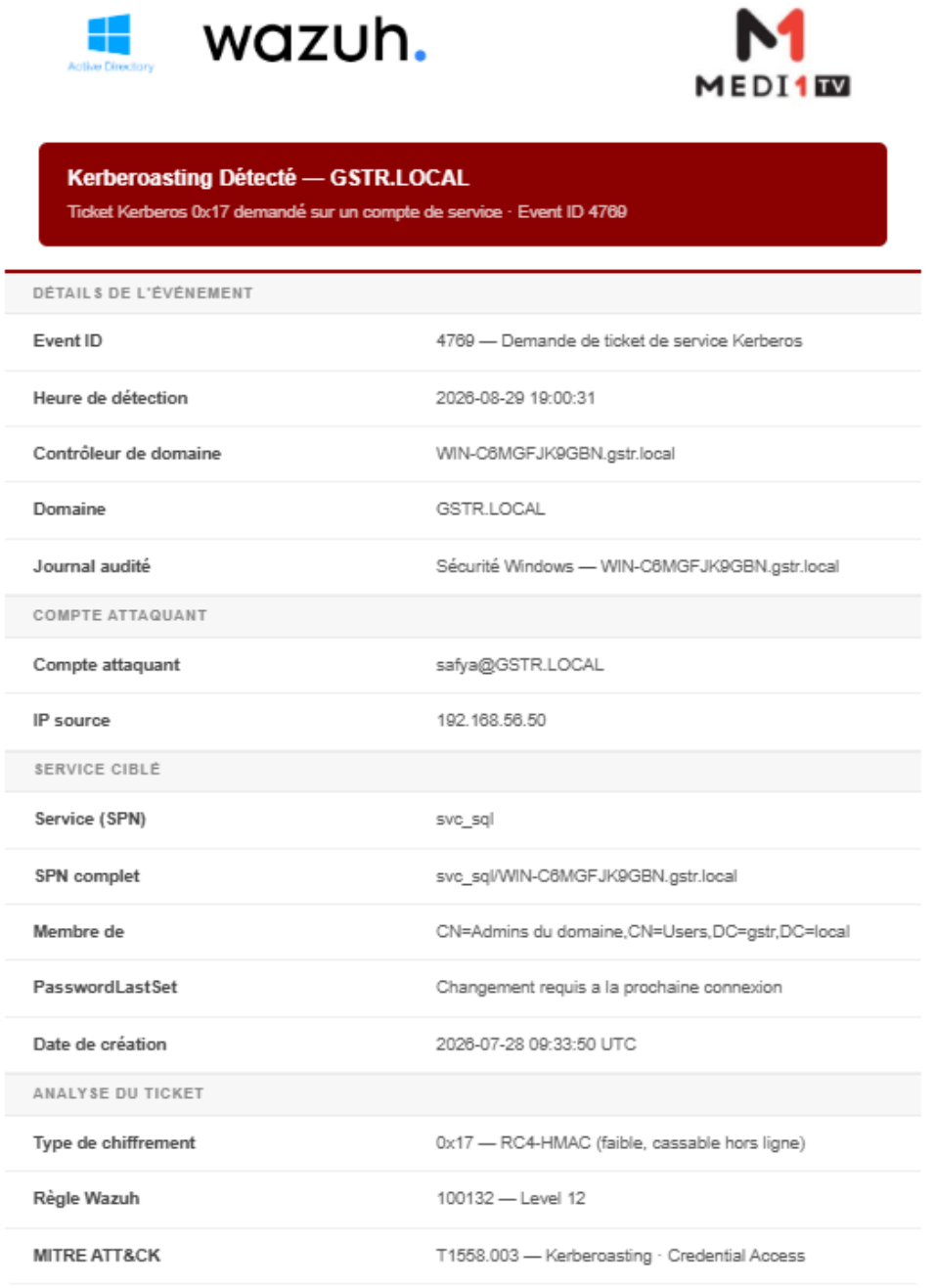


_index	wazuh-alerts-4.x-2026.08.29
agent.id	003
agent.ip	192.168.56.30
agent.name	WIN-C6MGFJK9GBN
data.win.eventdata.ipAddress	::ffff:192.168.56.50
data.win.eventdata.ipPort	46932
data.win.eventdata.logonGuid	{ec0651e3-2d32-f811-941a-42f49176064c}
data.win.eventdata.serviceName	svc_sql
data.win.eventdata.serviceSid	S-1-5-21-1868912242-2377486406-2398350158-1116
data.win.eventdata.status	0x0
data.win.eventdata.targetDomainName	GSTR.LOCAL
data.win.eventdata.targetUserName	safya@GSTR.LOCAL
data.win.eventdata.ticketEncryptionType	0x17
data.win.eventdata.ticketOptions	0x40810010
data.win.system.channel	Security
data.win.system.computer	WIN-C6MGFJK9GBN.gstr.local
data.win.system.eventID	4769
data.win.system.eventRecordID	28445
data.win.system.keywords	0x8020000000000000
data.win.system.level	0
data.win.system.message	"Un ticket de service Kerberos a été demandé. Informations sur le compte : Nom du compte : safya@GSTR.LOCAL Domaine du compte : GSTR.LOCAL GUID d'ouverture de session : {ec0651e3-2d32-f811-941a-42f49176064c}

FIGURE 3.6 – Vérification de l'alerte Kerberoasting dans Wazuh

3.6 Notification par e-mail

Une notification peut transmettre les informations essentielles de l'alerte, notamment le compte de service, l'adresse source et la technique MITRE associée. La capture ci-dessous doit correspondre au message effectivement reçu.



Kerberoasting Détecté — GSTR.LOCAL

Ticket Kerberos 0x17 demandé sur un compte de service · Event ID 4769

DÉTAILS DE L'ÉVÉNEMENT	
Event ID	4769 — Demande de ticket de service Kerberos
Heure de détection	2026-08-29 19:00:31
Contrôleur de domaine	WIN-C8MGFJK9GBN.gstr.local
Domaine	GSTR.LOCAL
Journal audité	Sécurité Windows — WIN-C8MGFJK9GBN.gstr.local
COMPTE ATTAQUANT	
Compte attaquant	safya@GSTR.LOCAL
IP source	192.168.56.50
SERVICE CIBLÉ	
Service (SPN)	svc_sql
SPN complet	svc_sql/WIN-C8MGFJK9GBN.gstr.local
Membre de	CN=Admins du domaine,CN=Users,DC=gstr,DC=local
PasswordLastSet	Changement requis a la prochaine connexion
Date de création	2026-07-28 09:33:50 UTC
ANALYSE DU TICKET	
Type de chiffrement	0x17 — RC4-HMAC (faible, cassable hors ligne)
Règle Wazuh	100132 — Level 12
MITRE ATT&CK	T1558.003 — Kerberoasting · Credential Access

FIGURE 3.7 – Notification par e-mail de l'alerte Kerberoasting

4 Détection du DCSync

4.1 Configuration des droits de réplication

Dans le cadre du scénario DCSync, **les droits Réplication des changements de répertoire**, **Réplication de toutes les modifications de l'annuaire** et **Réplication des changements de répertoire dans un ensemble filtré** ont été attribués au compte benali au niveau du domaine Active Directory, comme présenté ci-dessous.

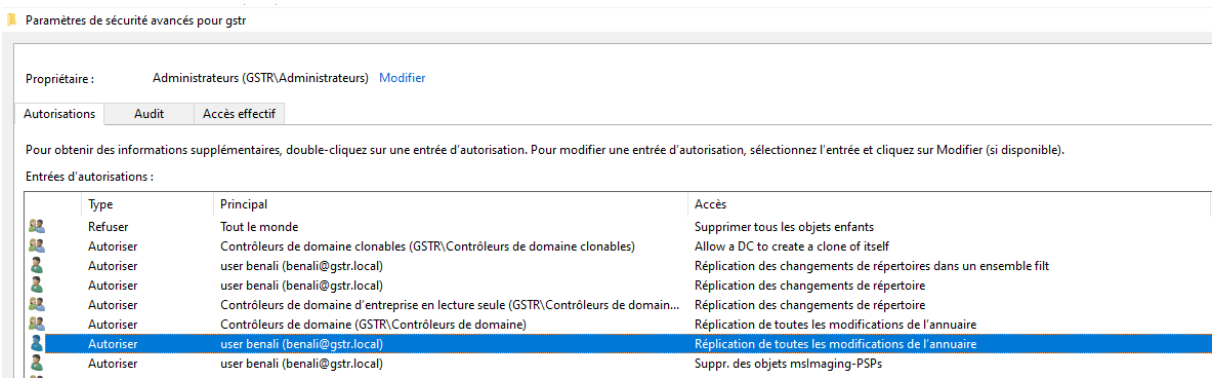


FIGURE 4.1 – Droits de réplication configurés pour le scénario DCSync

4.2 Configuration de l'audit Active Directory

La détection repose notamment sur l'événement Windows **4662**, qui nécessite l'activation de l'audit d'accès au service d'annuaire ainsi qu'une configuration SACL appropriée sur l'objet du domaine.

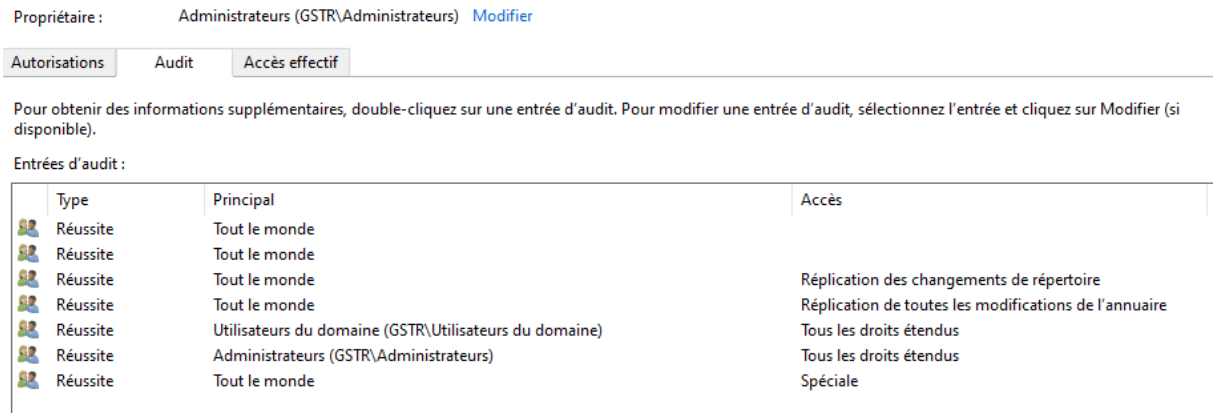


FIGURE 4.2 – Configuration SACL pour l'audit des droits de réplication Active Directory

4.3 Simulation de l'attaque

Une requête de réplication est simulée depuis Kali Linux dans l'environnement de test. Le résultat permet de vérifier le comportement du contrôleur de domaine et les événements générés.

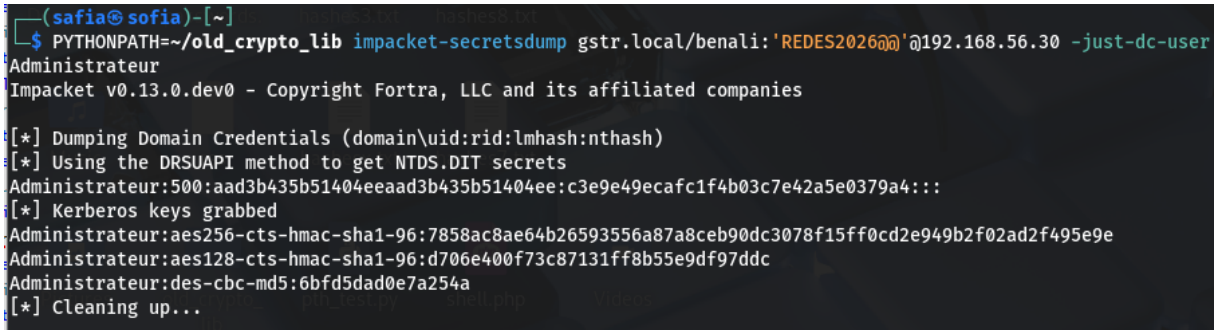


FIGURE 4.3 – Attaque par DCSync

4.4 Règle de détection Wazuh

Une règle personnalisée 100210 a été définie dans Wazuh pour détecter les activités suspectes de réplication Active Directory. Elle s'appuie sur l'événement Windows 4662 et les identifiants des droits de réplication, tout en tenant compte des opérations légitimes effectuées par les contrôleurs de domaine et les comptes autorisés.

```
<rule id="100900" level="15">
  <if_sid>60103</if_sid>
  <field name="win.system.eventID">^4662$</field>
  <field name="win.eventdata.properties" type="pcre2">\{1131f6aa-9c07-11d1-f79f-00c04fc2dcd2\}|\{1131f6ad-9c07-11d1-f79f-00c04fc2dcd2\}|\{89e95b76-444d-4c62-991a-0facbeda640c\}</field>
  <options>no_full_log</options>
  <ignore>120</ignore>
  <description>DCSync détecté : réplication AD demandée par $(win.eventdata.subjectUserName)</description>
  <mitre>
    <id>T1003.006</id>
  </mitre>
  <group>attack,credential_access,gstr</group>
</rule>
```

FIGURE 4.4 – Règle personnalisée Wazuh de détection du DCSync

4.5 Vérification de l'alerte

La validation repose sur la vérification de l'événement Windows 4662, du compte ayant effectué l'opération de réplication et de l'alerte correspondante générée dans le tableau de bord Wazuh, comme présenté ci-dessous.

Table JSON

_index	wazuh-alerts-4.x-2026.08.29
agent.id	003
agent.ip	192.168.56.30
agent.name	WIN-C6MGFJK9GBN
data.win.eventdata.accessList	%%7688
data.win.eventdata.accessMask	0x100
data.win.eventdata.handleId	0x0
data.win.eventdata.objectName	%{4173491e-44cc-448a-b2c9-e37296b79190}
data.win.eventdata.objectServer	DS
data.win.eventdata.objectType	%{19195a5b-6da0-11d0-afd3-00c04fd930c9}
data.win.eventdata.operationType	Object Access
data.win.eventdata.properties	%%7688 {1131f6ad-9c07-11d1-f79f-00c04fc2dcd2} {19195a5b-6da0-11d0-afd3-00c04fd930c9}
data.win.eventdata.subjectDomainName	GSTR
data.win.eventdata.subjectLogonId	0x4cae00
data.win.eventdata.subjectUserName	benali
data.win.eventdata.subjectUserSid	S-1-5-21-1868912242-2377486406-2398350158-1121
data.win.system.channel	Security
data.win.system.computer	WIN-C6MGFJK9GBN.gstr.local
data.win.system.eventID	4662
data.win.system.eventRecordID	28720
data.win.system.keywords	0x8020000000000000

FIGURE 4.5 – Alerte DCSync dans le tableau de bord Wazuh

4.6 Notification par e-mail

La notification de sécurité présente les informations de la requête de réplication suspecte et les éléments nécessaires à son investigation.

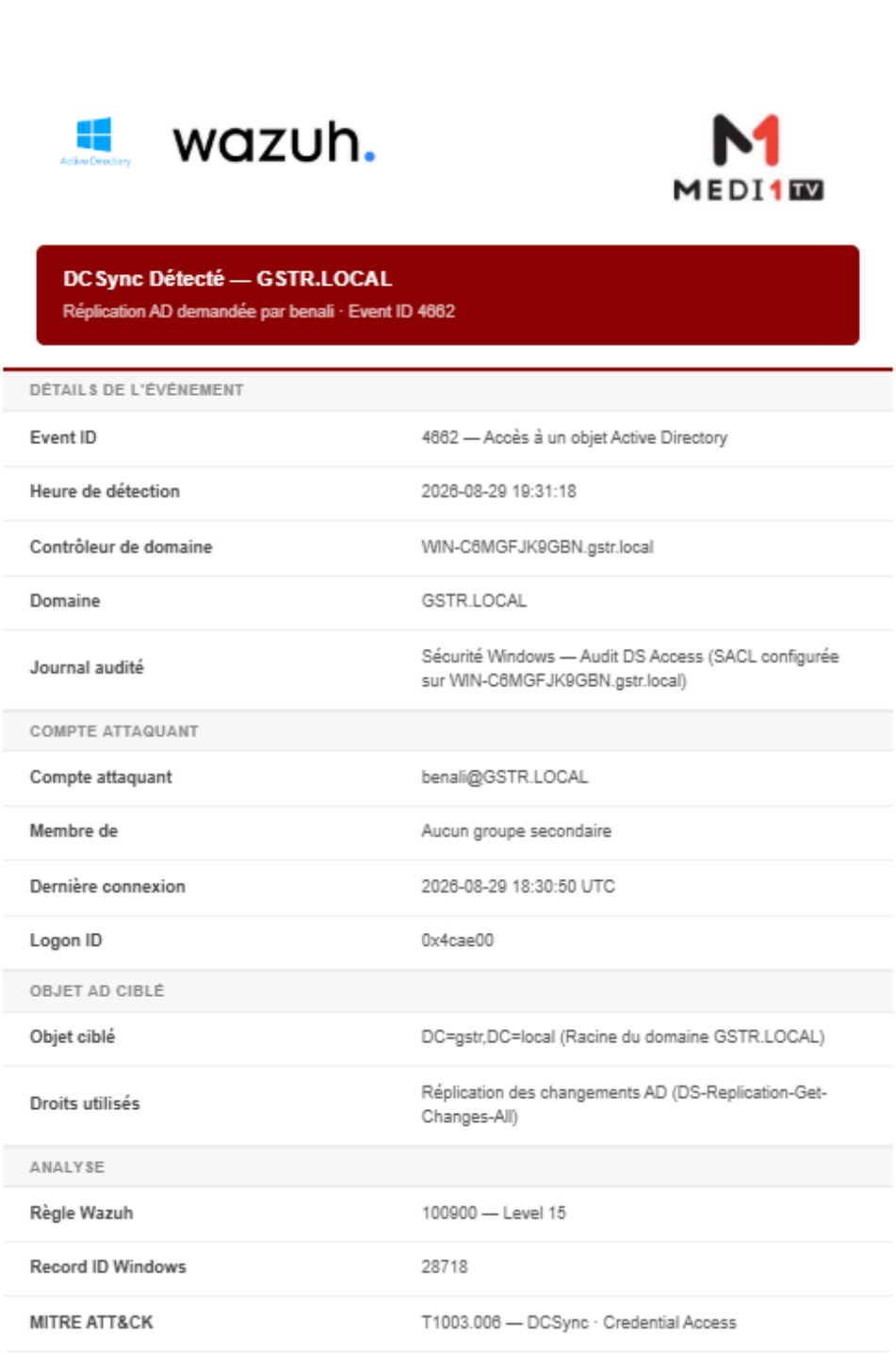


FIGURE 4.6 – Notification par e-mail de l'alerte DCSync

5 Détection du Pass-the-Hash

5.1 Préparation du scénario

Dans ce scénario, le hash NTLM précédemment récupéré lors de l'attaque DCSync est réutilisé pour réaliser une attaque Pass-the-Hash, sans avoir besoin de connaître le mot de passe en clair du compte concerné.

5.2 Simulation de l'authentification NTLM

Le script Python **pass_the_hash.py** est exécuté afin de simuler une authentification NTLM à partir du hash précédemment récupéré. Le résultat confirme l'accès aux ressources partagées de la machine cible avec les privilèges du compte utilisé.

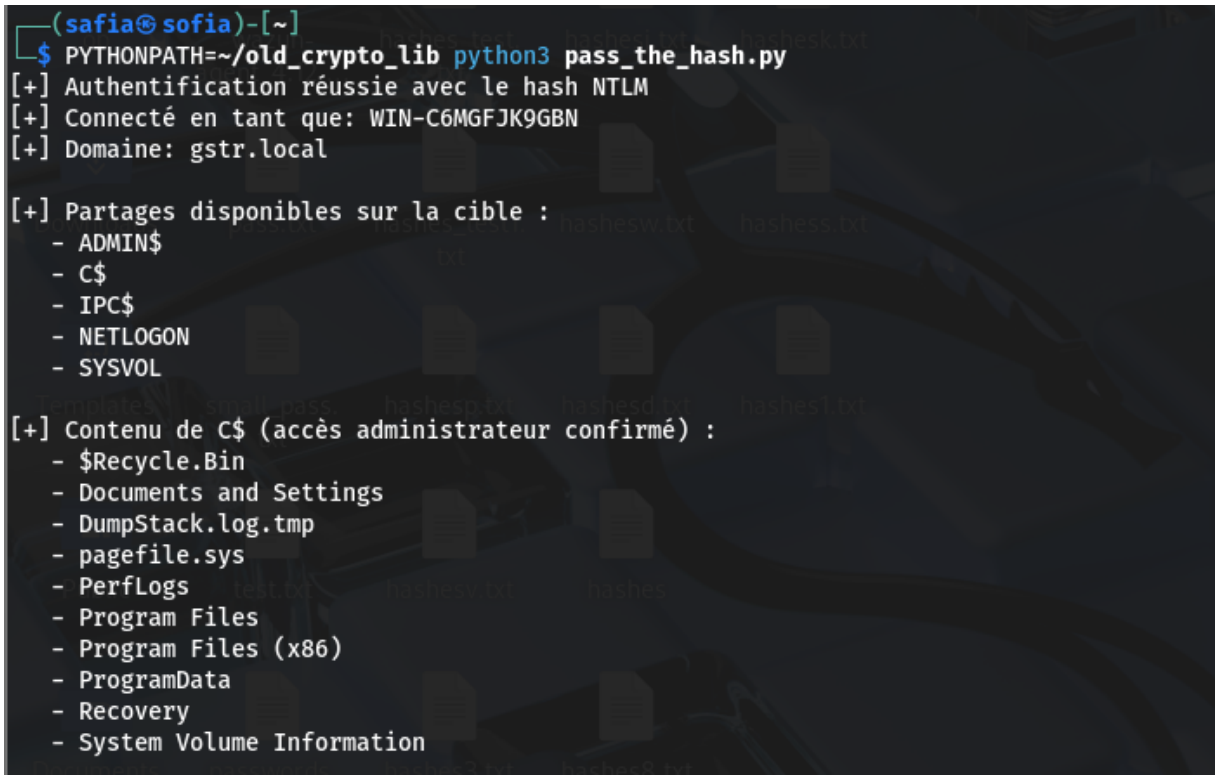


FIGURE 5.1 – Tentative de connexion distante avec Evil-WinRM à l'aide du hash NTLM



FIGURE 5.2 – Enter Caption

5.3 Règle de détection Wazuh

Une règle personnalisée 100901, de niveau de sévérité 12, a été définie dans Wazuh pour détecter les authentifications réseau NTLM suspectes. Elle s'appuie sur la règle parente 60103 et vérifie le type de connexion 3, l'utilisation du protocole NTLM ainsi que la présence d'une adresse IP source. Un délai d'ignorance de 120 secondes est appliqué afin de limiter la répétition des alertes.

```
<rule id="100901" level="12">
  <if_sid>60103</if_sid>
  <field name="win.system.eventID">^4624$</field>
  <field name="win.eventdata.authenticationPackageName">^NTLM$</field>
  <field name="win.eventdata.logonType">^3$</field>
  <options>no_full_log</options>
  <ignore>120</ignore>
  <description>Pass the Hash : authentification NTLM réseau réussie pour le compte $(win.eventdata.targetUserName)</description>
  <mitre>
    <id>T1550.002</id>
  </mitre>
  <group>attack,lateral_movement,gstr</group>
</rule>
```

FIGURE 5.3 – Règle Wazuh associée à la détection du Pass-the-Hash

5.4 Vérification de l'alerte

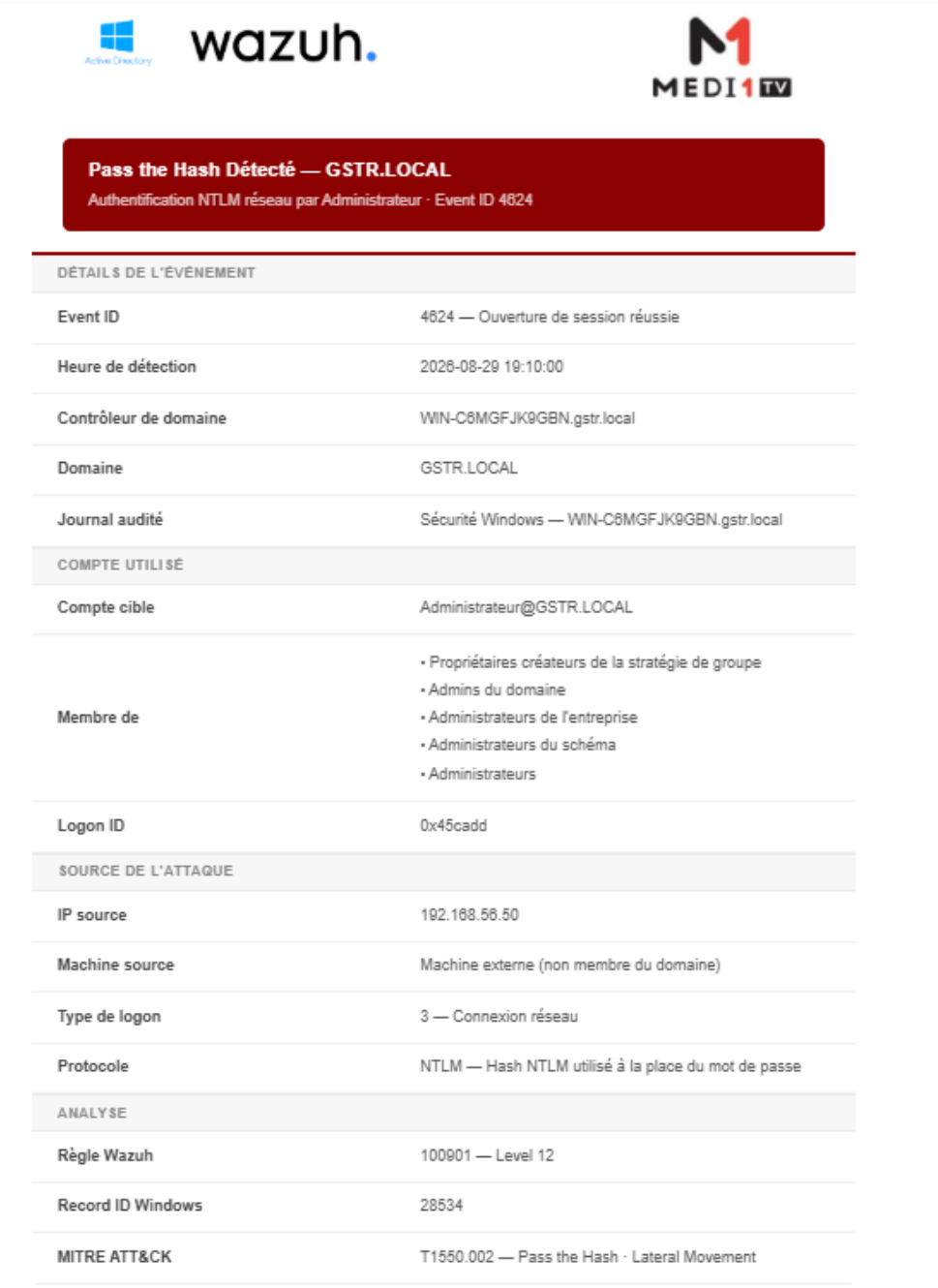
Suite à la simulation de l'authentification NTLM, la règle personnalisée 100901 se déclenche et génère une alerte dans le tableau de bord Wazuh, comme présenté ci-dessous. L'alerte permet d'identifier le compte concerné, l'adresse IP source et le type de connexion.

t	**_index**	**wazuh-alerts-4.x-2026.08.29**
t	**agent.id**	**003**
t	agent.ip	192.168.56.30
t	agent.name	WIN-C6MGFJK9GBN
t	data.win.eventdata.authenticationPackageName	NTLM
t	data.win.eventdata.elevatedToken	%%1842
t	data.win.eventdata.impersonationLevel	%%1833
t	data.win.eventdata.ipAddress	192.168.56.50
t	data.win.eventdata.ipPort	54958
t	data.win.eventdata.keyLength	128
t	data.win.eventdata.lmPackageName	NTLM V2
t	data.win.eventdata.logonGuid	{00000000-0000-0000-0000-000000000000}
t	data.win.eventdata.logonProcessName	NtLmSsp
t	data.win.eventdata.logonType	3
t	data.win.eventdata.processId	0x0
t	data.win.eventdata.subjectLogonId	0x0
t	data.win.eventdata.subjectUserSid	S-1-0-0
t	data.win.eventdata.targetDomainName	GSTR
t	data.win.eventdata.targetLinkedLogonId	0x0
t	data.win.eventdata.targetLogonId	0x45cadd
t	data.win.eventdata.targetUserName	Administrateur

FIGURE 5.4 – Alerte Wazuh générée lors du scénario Pass-the-Hash

5.5 Notification par e-mail

Suite au déclenchement de la règle, une notification par e-mail est envoyée afin de signaler l'activité NTLM suspecte. Elle contient les informations essentielles de l'alerte, notamment le compte concerné, l'adresse IP source et le niveau de sévérité, comme présenté ci-dessous.



wazuh.

MEDI1 TV

Pass the Hash Détecté — GSTR.LOCAL

Authentification NTLM réseau par Administrateur · Event ID 4624

DÉTAILS DE L'ÉVÉNEMENT	
Event ID	4624 — Ouverture de session réussie
Heure de détection	2026-08-29 19:10:00
Contrôleur de domaine	WIN-C8MGFJK9GBN.gstr.local
Domaine	GSTR.LOCAL
Journal audité	Sécurité Windows — WIN-C8MGFJK9GBN.gstr.local
COMPTE UTILISÉ	
Compte cible	Administrateur@GSTR.LOCAL
Membre de	• Propriétaires créateurs de la stratégie de groupe • Admins du domaine • Administrateurs de l'entreprise • Administrateurs du schéma • Administrateurs
Logon ID	0x45cadd
SOURCE DE L'ATTAQUE	
IP source	192.168.56.50
Machine source	Machine externe (non membre du domaine)
Type de logon	3 — Connexion réseau
Protocole	NTLM — Hash NTLM utilisé à la place du mot de passe
ANALYSE	
Règle Wazuh	100901 — Level 12
Record ID Windows	28534
MITRE ATT&CK	T1550.002 — Pass the Hash · Lateral Movement

FIGURE 5.5 – Notification par e-mail de l'alerte Pass-the-Hash